Future Generation Computer Systems 108 (2020) 68–81

Contents lists available at ScienceDirect

Future Generation Computer Systems

journal homepage: www.elsevier.com/locate/fgcs

Mirror saturation in amplified reflection Distributed Denial of Service: A case of study using SNMP, SSDP, NTP and DNS protocols

João J.C. Gondim [a], Robson de Oliveira Albuquerque [b], Ana Lucila Sandoval Orozco [b,c,*]

[a] Post Graduation in Electrical Engineering (PPEE), Department of Computer Science, University of Brasília, 70910-900 Brasília, Brazil
[b] Post Graduation in Electrical Engineering (PPEE), Department of Electrical Engineering, University of Brasília, 70910-900 Brasília, Brazil
[c] Group of Analysis, Security and Systems (GASS), Department of Software Engineering and Artificial Intelligence (DISIA), Faculty of Computer Science and Engineering, Office 431, Universidad Complutense de Madrid (UCM), Calle Profesor José García Santesmases, 9, Ciudad Universitaria, 28040 Madrid, Spain

ARTICLE INFO

Article history:
Received 28 August 2019
Received in revised form 26 December 2019
Accepted 13 January 2020
Available online 17 January 2020

Keywords:
Amplified reflection
DDoS
IoT
Mirror saturation

ABSTRACT

Over the last six years, there have been two major game changers in Distributed Deny of Service (DDoS) attacks: amplified reflection and the Internet of Things (IoT). Together, they motivated well-founded security concerns relating to IoT's offered attack surface, and how it could potentialize DDoS. In order to assess those concerns, the feasibility of IoT device abuse as reflectors were evaluated in this paper. Attacks abusing four protocols were tested showing a pattern that indicates that reflector saturates without sustaining maximum amplification rates, for very low injection rates (between 10 and 100 probe/sec). Hence, if on the one hand IoT devices, in general, would not be considered good reflectors, they would be good injectors. Any prepared attacker could thus use more injectors while maintaining low injection rates. This would certainly require greater coordination from the attacker but tends to hamper detection. It is expected to new levels of higher sophistication in DDoS attack execution, as in carpet bombing and pulse attacks, with the evolution of Command and Control (C2) incorporating orchestration and attack coordination.

© 2020 Published by Elsevier B.V.

1. Introduction

Denial of Service (DoS) attacks has been around on the Internet since the mid 70's [1]. Architecturally, the first breakthrough in volumetric DoS was when the attack was distributed and included several sources of traffic [2]. Initially, groups of manually compromised hosts (slaves or bots) under central coordination (of a master) executed attacks of much high volume against targets. However, attack preparation demanded a considerable effort.

DDoS takes a significant leap in traffic volumes when self-propagating malware started being used for building large networks of slaves (botnets). Then, preparation was much simpler but still involved developing some appropriate malware to infect, control, propagate and execute attacks. The architecture changed and masters become command and control (C2) centers with bots reporting to them after infection. Botnets were formed including thousands of bots, in contrast with zombie nets which were much smaller. As a direct consequence, attack volumes lept from Mbps to Gbps.

The next further improvement and first of the game changers in recent years was the introduction of amplified reflection. Paxson described them initially [3] and Rossow revisited them in [4] after their use in the mid 2010s. In an amplified reflection DDoS attack (AR-DDoS) preparation takes virtually minimum effort. There is no need to infect a host and install malware on them. It only requires certain particular configurations in hosts to abuse them as reflectors. The effort for probing for a potential reflector is the same as that of triggering an attack.

This work is an enhanced and extended version of [5]. The objective is to extend the study of mirror saturation dynamics assessing reflector behavior for other protocols to further evaluate if AR-DDoS can further potentialize the threat posed by IoT by running tests which are attacks executed in a controlled and segregated environment. The methodology used is consistent with that initially presented in [6].

1.1. Main contributions of this work

This work evaluated four protocols and their behavior over AR-DDoS situations. So the principal contributions are:

* Corresponding author at: Post Graduation in Electrical Engineering (PPEE), Department of Electrical Engineering, University of Brasília, 70910-900 Brasília, Brazil.
E-mail addresses: gondim@unb.br (J.J.C. Gondim), robson@redes.unb.br (R. de Oliveira Albuquerque), asandoval@redes.unb.br, asandoval@fdi.ucm.es (A.L. Sandoval Orozco).

https://doi.org/10.1016/j.future.2020.01.024
0167-739X/© 2020 Published by Elsevier B.V.

- Study mirror saturation dynamics assessing reflector behavior for protocols SNMP, SSDP, NTP, and DNS;
- Comparison and characterization of saturation for those; and
- Provide a further indication that for using IoT devices effectively increases attack complexity.
- Identify possible evolution trends in AR-DDoS and its consequences in terms of detection and mitigation requirements.

1.2. Outline of paper

This paper is organized as follows. Section 3 describes the attacks examined. Section 4 describes tests executed and the methodology used. Results (Section 5), along with their discussion, are presented in the sequel. Section 7 present conclusions and further directions.

2. Related work

[7] and [8] demonstrate that the lack of security in IoT devices makes them so attractive to attacks in general where DDoS is preferential due to their limited resources, which hinder the use of adequate security techniques to protect them.

The potential impact of reflexive DDoS and its possible use of IoT devices motivate different approaches of investigation. In [9] a methodology for measuring the properties of individual devices participating in DDoS attacks (like rate limiting, amplification factor, and speed) is introduced which allows the calculation of each device's actual contribution to the attack capacity. In [10] the IPv4 address space was scanned to evaluate the threat potential of AR-DDoS corresponding to certain protocols. In [11] the impact of a distributed denial-of-service attack in computer systems is evaluated proposing hierarchical models that represent the behavior of major system components and assess the effects of a DDoS attack on the system availability and IoT has already demonstrated its potential for DDoS, with several incidents (e.g. [12–14] and [15]), being Mirai [16] the most remarkable so far. However, Mirai did not use AR-DDoS [17] generating speculation about possible AR-DDoS attacks abusing IoT devices. Previous work [18] and [6] addressed this question indicating mirror saturation, but the first was a simulation and the other tested only one protocol.

In [19] the possibility of IoT devices being integrated into UDP-based Distributed Reflective DoS Attack (DRDoS) attacks and to flood a network as well as their potential to form a targeted attack on a particular victim machine is investigated.

3. Attack preliminaries

DoS attacks aim at exhausting device or infrastructure resources in order to cause service unavailability. One common form of implementing and potentializing DoS attacks is using distribution (distributed DoS, DDoS), in which several nodes send traffic in a coordinated way, resulting in higher attack efficiency and more complex mitigation given source obfuscation. There are several forms of DoS attacks, which can be organized in two major classes: volumetric attacks, and low and slow attacks.

In its low and slow form, legitimate traffic is sent to force service disruption exploiting specific protocol features, characteristics, or implementation details leading to exhausting some of the victim's resources, and consequently, legitimate requests are not properly responded to ordinary users. On the other hand, in its volumetric form, it includes attacks where large traffic volumes flood the victim, exceeding its processing capacity or link bandwidth so that either overwhelm services when attempting to process them or exceed traffic limits [20]. As a consequence, legitimate requests are not treated (see Fig. 1 for a simple DDoS attack taxonomy).

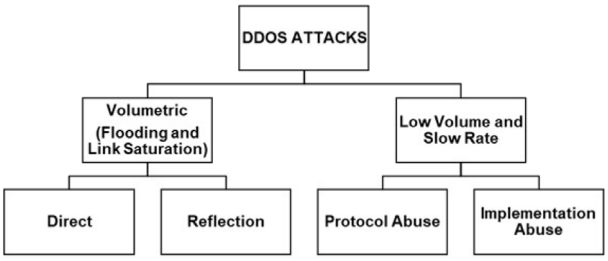


Fig. 1. DDoS attack taxonomy.

As for volumetric attacks, they can also be divided into direct attacks and reflection attacks. Both forms try to overload some victim resources (usually bandwidth) by sending large traffic volumes to the victim. In direct flooding attacks, compromised nodes send traffic straight to the victim; while in reflection attacks, intermediate nodes (reflectors) are used to flood the victim. For the purposes of the attacker, a reflector is any node that sends an IP datagram in response to one previously received. For AR-DDoS, reflectors of interest are those that amplify the amount of data sent; i.e., their response produces more bytes or packets, or both, than the original input request datagram. This behavior is characterized by a reflection factor, indicating how much traffic is generated by the reflector. So, amplifying reflectors potentialize traffic generated by an attacker [3].

A final ingredient common to most DoS attacks, including AR-DDoS, is IP spoofing, which consists of crafting arbitrary source addresses in IP datagrams. In DoS attacks, attackers use this technique to obfuscate the real attack source, thus making the mitigation of the attack harder. Characteristically, in AR-DDoS, attackers send traffic to reflectors using the victim's address as source address [21]. These characteristics add levels of obfuscation complexity to the victim's mitigation process. For instance, the attacker's original source is not seen in the attack's traffic and due to the number of reflectors used, the mitigation has to deal with thousands of different IP sources, making it very difficult to implement ordinary filters to block IP addresses, leading to much more complex mitigation strategies.

[7] and [8] demonstrate that the lack of security in IoT devices makes them so attractive to attacks in general where DDoS is preferential due to their limited resources, which hinder the use of adequate security techniques to protect them.

3.1. Modus operandi

From the operational perspective, AR-DDoS has a scan, or preparation phase, where potential reflectors are identified, followed by an effective attack. In both phases, a probe datagram, which depends on the protocol abused, is crafted to stimulate the reflector to produce an amplified response. The difference between the probe for scan and the one for an attack is that in the scan the source IP address is the attacker's while in the attack it is the target's. The operation in both phases takes the following steps:

(a) A probe request is generated by the attacker with the appropriate parameter to obtain amplification;
(b) A UDP datagram for the message is generated with the corresponding protocol port;
(c) An IP packet with a destination address equal to that of the reflector is created and:

- in case of attack, a spoofed source address to match the target's address;
- in case of the scan, the attacker's address as the source address.

The UDP datagram is then placed in an IP packet;

(d) The UDP datagram is placed in an IP packet and sent normally to the reflector;

(e) The reflector receives the packet, processes it and generates a long response with the values for the required variables;

(f) Finally, the reflector sends the message:

- in case of attack, to the target;
- in case of scan, to the attacker.

In the case of an attack, the steps above are executed while the attack lasts.

Note that the preparation effort comprises only the scan. It is minimal when compared to other forms of DDoS.

3.2. Attack overview with SNMP protocol

SNMP is the Simple Network Management Protocol [22]. It defines how managed devices and management stations communicate and exchange information. Managed devices run agents and maintain a database, the Management Information Base (MIB), that contains variables representing management data. These variables can be used both for monitoring and for invoking actions on managed nodes. The requests for query or change of variables are made through messages sent via UDP port 161.

In versions 1 and 2c, message authentication is based on the value of the "community" field, which is encoded as full text and transmitted in the clear. There is a "public" community that comes as default [23]. Because SNMP supports messages sent via UDP, IP packet spoofing is trivial. In this way, an SNMP message with IP spoofing and "community" field equal to "public" allows directing MIB information to a third party. In version 2 and derivatives a new GetBulkRequest request message was implemented, which serves to retrieve the value of several variables, including lines of tabular variables, in only one message. A tabular variable is one that can have multiple iterations, which represent a row in a table. If the value of the "max repetitions" argument of the GetBulkRequest message exceeds the number of rows in the table, the next MIB variables are returned. In this way, an attacker can send a GetBulkRequest with a high number of "max-repetitions", generating a response message with significant size. Unlike more recent protocols, SNMP has no recommendation for limiting the response interval. However, because of the large processing cost of GetBulkRequest, especially when accessing variable-length tables, the responder may not be able to send the responses immediately.

3.2.1. Probe datagram

For SNMP, the probe datagram must be crafted as follows:

- Version is 2c and community is "public"
- It is a GetBulkRequest request with the identifier of one or more tabular variables.
- The "non-repeaters" field should be 0, which indicates that there are no scalar variable identifiers in the message.
- The value of the "max-repetitions" field must be high (typically 2250) but chosen such that the answer does not exceed the limit size defined by Internet Protocol version 4 (IPv4), that is, 65,535 bytes;
- UDP port is 161, which is reserved for SNMP.

3.3. Attack overview with SSDP protocol

Simple Service Discovery Protocol (SSDP) and is part of Universal Plug and Play (UPnP), which was created to extend the concept of "plug-and-play" to devices over a network. The version used in the tests conducted in this paper was 1.0 (the most used [24]) and it is defined in UDA 1.0 (UPnP Device Architecture) specification [25]. SSDP uses a multicast HTTP variant over UDP port 1900.

SSDP has control points that can at any time send an M-SEARCH request to search for devices in the network. Each device then sends messages corresponding to the root device, its embedded devices, and its services. The response, in addition to generating messages larger than an M-SEARCH, generates more than one message, since a device is expected to have minimally one service, which generates a message for the root device and another for the service, evidencing the potential for amplification. Each root device with d embedded devices and k different kinds of service generates $(3 + 2d + k)$ messages. In order to avoid network congestion, SSDP uses the MX field of the M-SEARCH message to indicate the maximum time for sending the response, as explained above in the discovery step. Although there is a recommendation for MX to be at least 1, the specification itself allows the devices to assume values lower than those specified by MX. This means that it is plausible to generate significant traffic.

Another point to note is that although the MX field is mandatory, the responding device behavior in relation to the value of this field is not mandatory. Thus, the ability to generate sustainable amplification depends on implementation. As reported in [26], most reflectors use the same implementations as in [24].

3.3.1. Probe datagram

For SSDP, the probe datagram must be forged according to the following steps:

- It is an M-SEARCH message is
- MX value equal to 1, the lowest recommended, and ST with a value equal to "ssdp:all", so that the message applies to all UPnP devices on the network;
- UDP port 1900 is used, which is reserved for SSDP;

3.4. Attack overview with NTP protocol

The Network Time Protocol (NTP) is the protocol that synchronizes a set of clocks across the network, through the client and server system, with nanosecond accuracy. It is currently in Version 4 (NTPv4), the most recent, defined in with RFC5905 [27]. Since then, several improvements have been implemented in the protocol, pending yet another publication of an RFC. From the attack perspective, its most relevant feature is the MONLIST command.

The MONLIST command operates in private mode, which is used to perform client–server information exchange sent over a UDP message on port 123. When the client sends this command to the server, the server returns to the client a list of the last 600 hosts that connected to it [28], as well as data such as source and destination IP address, NTP version, and package mode. Among the various commands available in the NTP protocol for monitoring purposes, MONLIST is of special importance for amplification purposes.

Each MONLIST request can receive up to 100 UDP datagrams of 440 bytes in payload size [4]. The amplification factor achieved can be very large since a request can have a minimum size of 8 bytes, while the response can contain thousands of bytes. It is reported that [4] a MONLIST request had an average amplification of 556.9× and the highest amplification rate was 4670×.

For amplification to be performed by the MONLIST command, three factors are necessary: (a) the NTP server is enabled to receive queries; (b) the MONLIST command is enabled on it; and (c) it is configured to answer requests from any customer and not just the locations.

The DDoS attack exploiting the NTP protocol would then take place as follows. First the attacker would need a list of open NTP servers. In possession of such list, the attacker would forge the source IPs of the packets to be sent, placing the victim's IP so the answer is sent to the victim. After that, the attacker would direct his efforts to send MONLIST requests to the open NTP servers that he knows of so they would act as packet reflectors and amplifiers. The victim would then receive a very large amount of data traffic and depending on the amount of it, the victim would overload generating a bottleneck and would not be able to respond to legitimate requests, thus suffering a denial of service.

3.4.1. Probe datagram

The probe datagram specification is:

- An NTP MONLIST request message setting the following values:
  - R = 0 - Operation is a Request;
  - VN = 2 - Version 2;
  - Mod = 7 - Private Mode;
  - Implementation = 3 - XNTPD Implementation.
  - Req. Code = 42 - *monlist*(MON_GETLIST_1) request code.

  the resulting message has code *0x1700032a* and all other remaining header fields are set to zero.
- UDP port is set to 123, NTP's reserved port;

3.5. Attack overview with DNS protocol

The Domain Name System (DNS) is an application layer protocol that is used to translate names into IP addresses and vice-versa. It functions as a distributed database running based on a server hierarchy. The concept and specifications of the protocol are detailed in RFC 1034 [29], RFC 1035 [30] and updated in several additional RFCs.

For queries on DNS servers, there are recursive and interactive methods. In a recursive query, the DNS server repeats the same basic process until it receives the related response. When a server receives a recursive request and does not have the response, it queries other servers, thus making another recursive query.

DNS servers respond queries using stored resource records that provide mappings of hostnames to IP addresses. Each DNS response message carries one or more resource records. A resource record is a four-element tuple that contains the following fields: Name, Value, Type, and TTL. There are only two types of messages in the DNS protocol, query, and reply. They have the same format, that is, the same fields in the header, distinguishing the answer questions only in the values filled in the fields.

One way the AR-DDoS attack abuses the DNS is by exploiting the *Type ANY* query message. This query returns all types of records for a given domain (types A, NS, CNAME, and MX) generating responses much larger than the request. The size of the response will depend on how much information that the queried DNS server zone has about the domain. In addition to master records, if the field *ADDITIONAL* is active then it is possible to receive more record types, such as AAAA which maps to IPv6 addresses, other DNS servers that contain domain information, and even text information as a payload of the message. Further amplification may be obtained if DNSSEC (an extension to DNS designed to provide greater security for the DNS protocol specified in RFC 2535 [31]) is active.

Table 1
DNS probe field value assignment for AR-DDoS.

Field	Name	Value	Field	Name	Value
1	ID	Random	14	NSCOUNT	0
2	QR	0	15	ARCOUNT	1
3	OPCODE	0	16	QUESTION	Queried domain name
4	AA	0	17	TYPE	255
5	TC	0	18	NAME	0
6	RD	1	19	TYPE	41
7	RA	0	20	CLASS	4096
8	Z	0	21	RCODE	0
9	AD	1	22	EDNS0	0
10	CD	0	23	Z	32 768
11	RCODE	0	24	RDLEN	12
12	QDCOUNT	1	25	RDATA	Random
13	ANCOUNT	0			

As a final remark, DNS must be forced to use only UDP transport. That requires proper settings in the header and buffer size. So in the header, the truncated bit, TC, must be set to 0 and the buffer size defined by field CLASS, requestor's UDP payload size, set to 4096.

3.5.1. Probe datagram

From the attack perspective, for the AR-DDoS to take place the DNS probe must be sent to a DNS mirror to generate amplified reflection with the target IP address used as the source address. The specific DNS probe must be set to the parameters detailed in Table 1. Fields 1 to 15 of the table are compulsory in the DNS header, each datagram must have them filled appropriately. Values chosen define a recursive query and also accept additional information if any is available. Fields 16 to 18 are in the query area and define the domain to be queried and query type (ANY). Remaining fields, 19 to 25, are in the additional area and establish that DNSSEC might be used and maximum response length is 4096 bytes, to accommodate additional information (RFC 2671 [32]).

The must probe datagram must forged according to the following steps:

- It is a DNS *Type ANY* query message with field values according to Table 1;
- UDP port is set to 53;

4. Methodology and tests scenarios

In order to be able to explore the attacks in the protocols explained earlier, this section provides details about the methodology used and the tests that were performed to achieve the amplification results provided by the attacks.

4.1. Methodology

The full methodology used in this paper is adopted and described in [6]. The decision for testing the selected protocols was guided by the criterion of reported protocol abuse in real-world events. Chosen protocols are commonly used in the attacks with varying maximum amplification rates. DNS and NTP were used in the first record-breaking attacks while SNMP and SSDP came afterward and are both also related to IoT environments. Recently, attacks abusing SSDP specifically had a significant rise [33].

For NTP and DNS, given that they have more mature and robust implementations, also they are easier to control the maximum amplification level when compared to SNMP and SSDP, tests were designed to gather information about the possible impact of the maximum amplification factor on the saturation behavior. So, for NTP and DNS, the tests included three rounds, each corresponding to one maximum amplification level.

The main objective of the tests was to study reflector saturation dynamics for several protocols as a basis for assessing possible use of IoT devices as mirrors in AR-DDOS. Devices were intentionally chosen with much more computing power than IoT devices so that hardware limitations would not influence results. Along the same line, tests avoided using wifi network connections, but cable connections instead.

4.1.1. Considerations about the attacks levels

Attacks were performed using specific levels, that could range from 1 to 10. For each attack level L, the number of probes per second generated by the attacker tool was given by:

$$Probe/s = 10^{(L-1)} \tag{1}$$

Two tools were used in tests: one for SNMP and SSDP; another for NTP and DNS. The second had enhancements in modularity and scalability but both had the same attack behavior. In the case of SNMP and SSDP, the attacks were carried out up to level 6. For NTP and DNS, tests reached level 8 in order to fully characterize saturation. Wireshark tool [34] ran on the attacker, reflector and target during attack rounds. Only data regarding reflectors are presented since analysis is focused on them.

4.1.2. Considerations about the metrics

From traffic captures collected, flows in bits per second (bps) and packets for second (pkt/s) for reflector inbound and outbound flows were obtained and amplification was calculated as:

$$Amp_{bit} = \frac{bit_{out}}{bit_{in}} \tag{2}$$

for bit amplification, where bits are considered from layer 3 upwards. So, IP and UDP headers are counted along with application protocol payload:

$$Amp_{bit}^{(3)} = \frac{IP_{hdr} + UDP_{hdr} + App_{resp}}{IP_{hdr} + UDP_{hdr} + App_{req}} \tag{3}$$

It must be acknowledged that Amp_{bit} is sometimes calculated considering only the application level payload.

$$Amp_{bit}^{(7)} = \frac{App_{resp}}{App_{req}} \tag{4}$$

With typical values for IP_{hdr} and UDP_{hdr} (20 bytes and 8 bytes respectively), it is clear that values calculated with Eq. (4) are roughly two times the value obtained with Eq. (3) where:

$$IP_{hdr} + UDP_{hdr} = 28 \approx App_{req} \tag{5}$$

$$IP_{hdr} + UDP_{hdr} = 28 \ll App_{resp} \tag{6}$$

and

$$Amp_{bit}^{(7)} \approx 2 \times Amp_{bit}^{(3)} \tag{7}$$

Eq. (3) is adopted as it better reflects attacker and reflector effective amplification effort in terms of total traffic volume.

Finally, the response datagram size in bytes may exceed the MTU (maximum transfer unit). Should that happen, amplification also occurs in terms of packets:

$$Amp_{pkt} = \frac{pkt_{out}}{pkt_{in}} \tag{8}$$

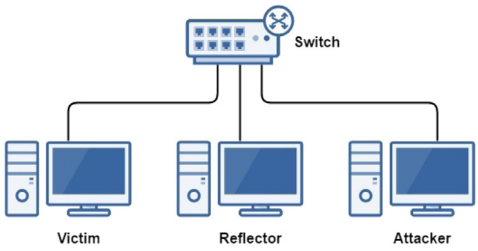


Fig. 2. Test topology common to all four scenarios.

Table 2
Configuration of scenario 1.

Configuration	Attacker	Reflector	Target
Processor	i7-4500U @ 1.80 GHz	i5-660 @ 3.33 GHz	i3-380M @ 2.53 GHz
RAM	8 GB DDR3L @ 1600 MHz	8 GB DDR3 @ 1333 MHz	4 GB DDR3 @ 1333 MHz
Network adaptor	RTL8136	RTL8111D Gb Ethernet	AR8152
O.S.	Win 10 Home x64 host v1803 VBox 5.2.18 (VNet in bridge mode 2) Ubuntu 14.04 guest system (64-bit)	Win 10 Pro x64	Win 10 Home x64 v1803

4.2. Tests scenarios

Tests were performed in four different scenarios, one for each of the four protocols and consisted of three rounds of 30-second duration each per attack level, based on the same network topology. The average results are presented in the corresponding tables in the Appendix.

Fig. 2 illustrates the topology common to all scenarios. Each scenario is composed of: an Attacker, which performed the attack sending probes to the reflector; a Reflector (or mirror) which runs the service which is abused in the attack; a Target, which is the final attack flow destination and it only executes Wireshark to collect attack data; and a Switch, the active networking device used to connect hosts.

Hardware to implement each scenario was intentionally chosen to provide diversity between tests, especially after tests with SNMP and SSDP, to provide supporting evidence regarding coincidental results.

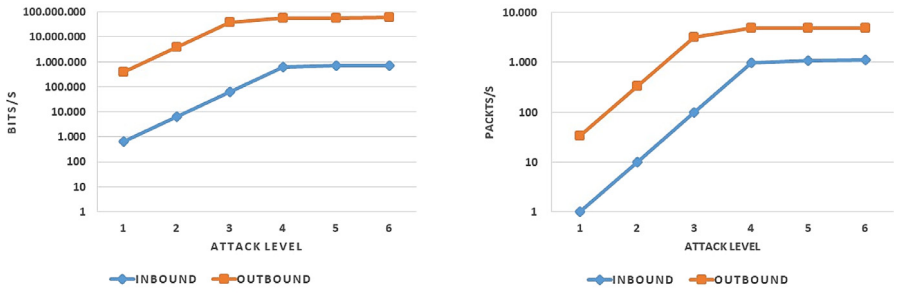
Each test scenario had its considerations and the implied hardware and software needs. They are described below.

4.2.1. Scenario 1 - tests with SNMP

Tests with SNMP used the devices described in Table 2 which shows the configuration of each device. The attacker ran Windows 10 operating system and hosting an Ubuntu 14.04 LTS virtual machine which effectively launched the attack while reflector also ran Windows Operating System with the SNMP service using Microsoft's implementation of the SNMP agent activated.

The setup was complete with a TP-Link TL-WDR4300 wireless router used as switch (as a reminder, the wifi connection was not used in such tests).

The tool used to perform the attack in SNMP was developed for Linux. Virtualization was used to make the attacker less powerful than the reflector due to VM overhead. This scenario was not tested in previous work. Since a virtual network card was used in bridge mode 2, the attacker's machine acted exactly as if it were connected to the same network of the reflector and target. This did not interfere with the results since reflector saturation



(a) bps (b) pkt/s

Fig. 3. SNMP attack.

Table 3
Configuration of scenario 3.

Configuration	Attacker	Reflector	Target
Processor	Intel Core i7 3,5 GHz	2,40 GHz Intel Core i3-520M	Intel Core i5-2410M 2,30 GHz
RAM	16 GB 2133 MHz LPDDR	4 GB 1333 MHz DDR3	4 GB 1333 MHz DDR3
Network adaptor	Type C Hub with Ethernet Adaptor 100 Mbps	AR8152 PCE-e Fast Ethernet Controller 100 Mbps	RTL 8139/810x Fast Ethernet 100 Mbps
O.S.	Ubuntu 16.04 LTS	Ubuntu 14.04 LTS	Windows 10 Professional

was achieved before the attacker saturated, even with the use of a reflector having superior hardware compared to a typical SNMP device.

4.2.2. Scenario 2 - tests with SSDP

Tests with SSDP used the same hardware e software environment as Scenario 1. The difference is that the Reflector runs the SSDP instead of SNMP. In this case, it was used Windows Operating System running Windows Media Player with UPnP for media sharing enabled. The tool used to perform the attack in SSDP was developed for Linux. Virtualization was used to make the attacker less powerful than the reflector due to VM overhead. This scenario with SSDP was not tested in previous work. It must be noted again that this did not interfere with the results since reflector saturation was achieved before the attacker saturated, even with the use of a reflector having superior hardware compared to a typical SSDP device or system.

4.2.3. Scenario 3 - tests with NTP

Table 3 shows the configuration of each device. used in NTP tests.

The active network device used was a Multilaser RE024 Wireless 150 Mbps router used only as a switch (this test did not use wifi connection).

4.2.4. Scenario 4 - tests with DNS

Table 4 shows the configuration of each device in the scenario used for tests with DNS. The active network device used was a Askey RTF3505VW-N2 1 Gbps router used only as a switch.

5. Results

After performing the tests in each scenario as described earlier, the main results and findings are described below.

Table 4
Configuration of scenario 4.

Configuration	Attacker	Reflector	Target
Processor	Intel i3-M370	Intel i5-8250U	Intel i5-4210U
RAM	4 GB DDR3 1333 MHz	8 GB DDR4 2400 MHz	8 GB DDR3 1600 MHz
Network adaptor	100 Mbps	1 Gbps	100 Mbps
O.S.	Lubuntu 19.04	Lubuntu 19.04	Lubuntu 19.04

5.1. Attack with SNMP

Table 5 shows the results for reflector behavior during the attack using SNMP in terms of bit and packet flows respectively.

As can be observed, maximum amplification rates, either in bits or in packets, are sustained only until attack level 3. From that point on, it decays but maintains some residual gain. This can be easily verified in Figs. 3a and 3b. It can also be observed that inbound traffic also saturates but from level 3 on, instead of level 2, as for the amplification.

5.2. Attack with SSDP

Results for reflector behavior during the attack using SSDP in terms of bit and packet flows are in Table 6.

Similarly to SNMP, the maximum amplification rates, either in bits or in packets, are sustained only up to attack level 2, in contrast with SNMP which went up to level 3. From that point on, it decays and maintains some residual gain in bits but attenuates in packets (Figs. 4a and 4b). Also, it can be observed, as for SNMP, that inbound traffic saturates but from level 3 on, instead of level 2, as for the amplification.

5.3. SNMP and SSDP amplification

Amplification factor behavior for SNMP is presented in Fig. 5a. As shown, for both attacks saturation occurs with amplification abruptly falling from level 3 on, in bits and in packets. SSDP Amplification factor behavior is presented in Fig. 5b similar to SNMP behavior. However, for SSDP amplification falls slightly from level 2 to 3 and then falls abruptly, both in bits and in packets.

5.4. Attack with NTP

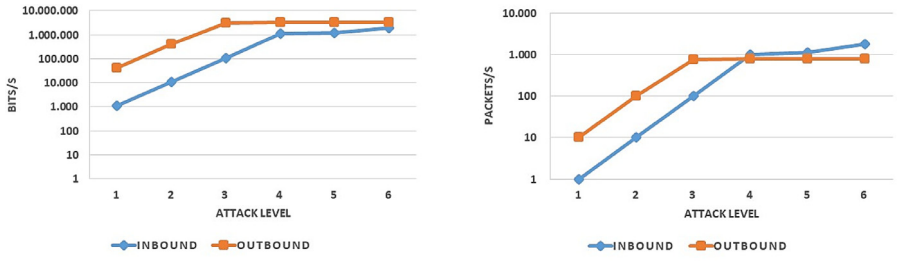
Tables 10 and 11 in the Appendix show results for reflector behavior for different maximum amplification factors, depending on the number of hosts in the MONOLIST command response (60 hosts, 300 hosts and 600 hosts) during the attack using

Table 5
SNMP attack.

Level	bps			pkt/s		
	Reflector		Amplification	Reflector		Amplification
	Inbound	Outbound		Inbound	Outbound	
1	647	394 468	609,03	1	33	33,40
2	6408	3 894 071	607,72	10	330	33,04
3	63 919	38 614 906	604,11	100	3.195	31,98
4	630 051	57 614 231	91,44	985	4.825	4,90
5	702 535	57 157 632	81,36	1098	4.815	4,39
6	719 934	59 061 424	82,04	1125	4.924	4,38

Table 6
SSDP attack.

Level	bps			pkt/s		
	Reflector		Amplification	Reflector		Amplification
	Inbound	Outbound		Inbound	Outbound	
1	1099	41 798	38,04	1	10	10,00
2	10 893	416 487	38,23	10	100	10,00
3	108 926	3 116 813	28,61	100	748	7,47
4	1 088 113	3 253 133	2,99	1000	777	0,78
5	1 227 497	3 279 005	2,67	1128	784	0,69
6	1 914 556	3 311 109	1,73	1758	793	0,45



(a) bps (b) pkt/s

Fig. 4. SSDP attack.

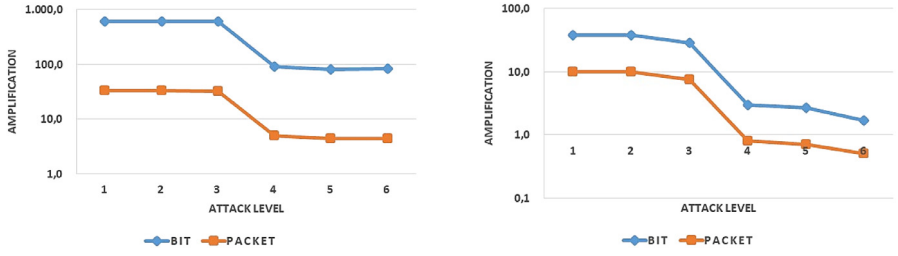


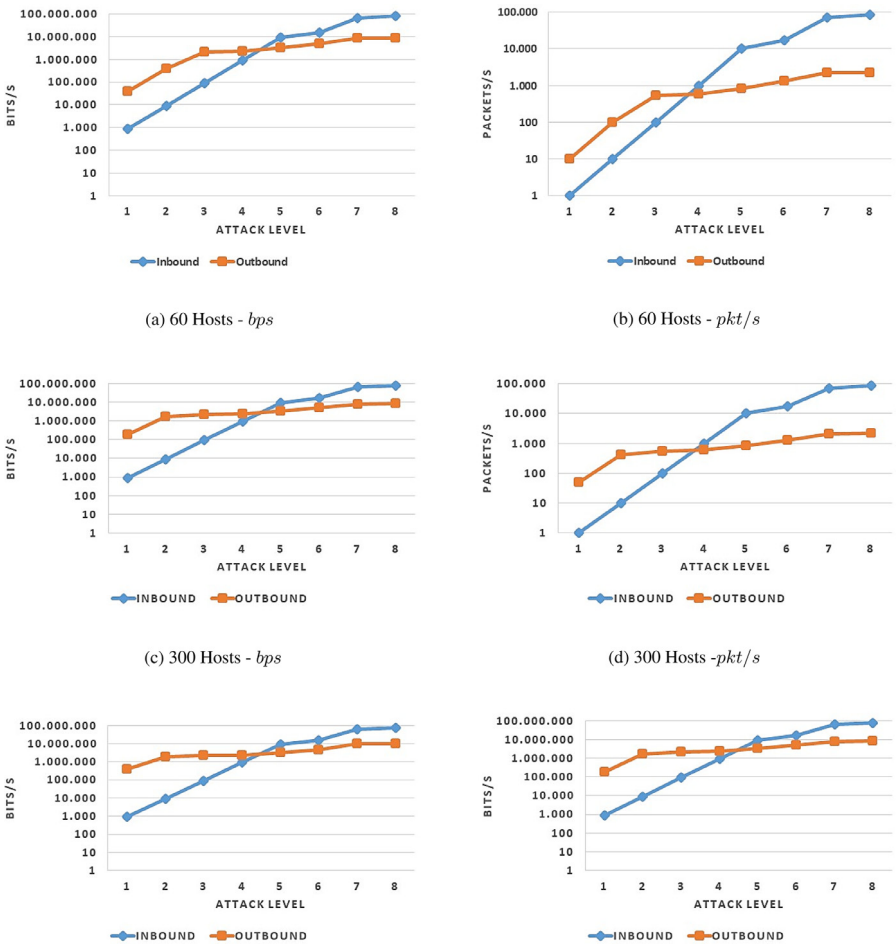
Fig. 5. SNMP and SSDP amplification.

NTP in terms of bit and packet flows respectively. Maximum amplification factors observed were, for bit rates: 42,28× for 60 hosts, 211,40× for 300 hosts and 422,81× for 600 hosts; whereas for packet rates observed values were: 10× for 60 hosts, 50× for 300 hosts and 100× for 600 hosts. This can be easily verified in Fig. 6.

As demonstrated by Figs. 6a and 6f, for the 60 host maximum amplification rate there is a slight decrease in amplification in level 2 (in bits and packets) with saturation consolidating at level 3. The observed behavior for the 300 host (Figs. 6c and 6d) and 600 host (Figs. 6f and 6f) maximum amplification rate differs from the previous rate with saturation consolidating from level 2 on, in bits and in packets. For all three maximum rates tested attenuation occurred from level 4 on, either in bits or in packets.

5.4.1. NTP amplification

Amplification factor behavior for NTP is presented in Figs. 7a and 7b for each of the three maximum amplification factors tested. For the 600 host amplification factor, the resulting graph decreases monotonically, both in bytes and in packets. For the other two amplification factors tested, (300 hosts and 60 hosts) both start saturating from level 2 on with amplification abruptly falling, in bits and in packets. It should also be noted that attenuation occurs from level 5 on in bytes and from level 4 on in packets. It is very interesting that graphs for all three maximum amplification factors converge from level 3 on, in bytes and in packets. This behavior suggests that NTP saturation is independent of the maximum amplification factor.



(a) 60 Hosts - *bps*

(b) 60 Hosts - pkt/s

(c) 300 Hosts - *bps*

(d) 300 Hosts -pkt/s

Fig. 6. NTP attack.

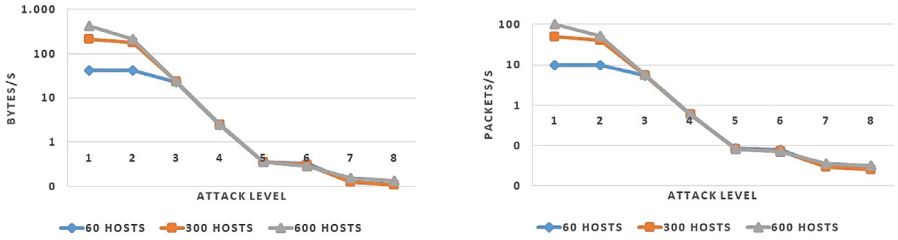


Fig. 7. NTP amplification.

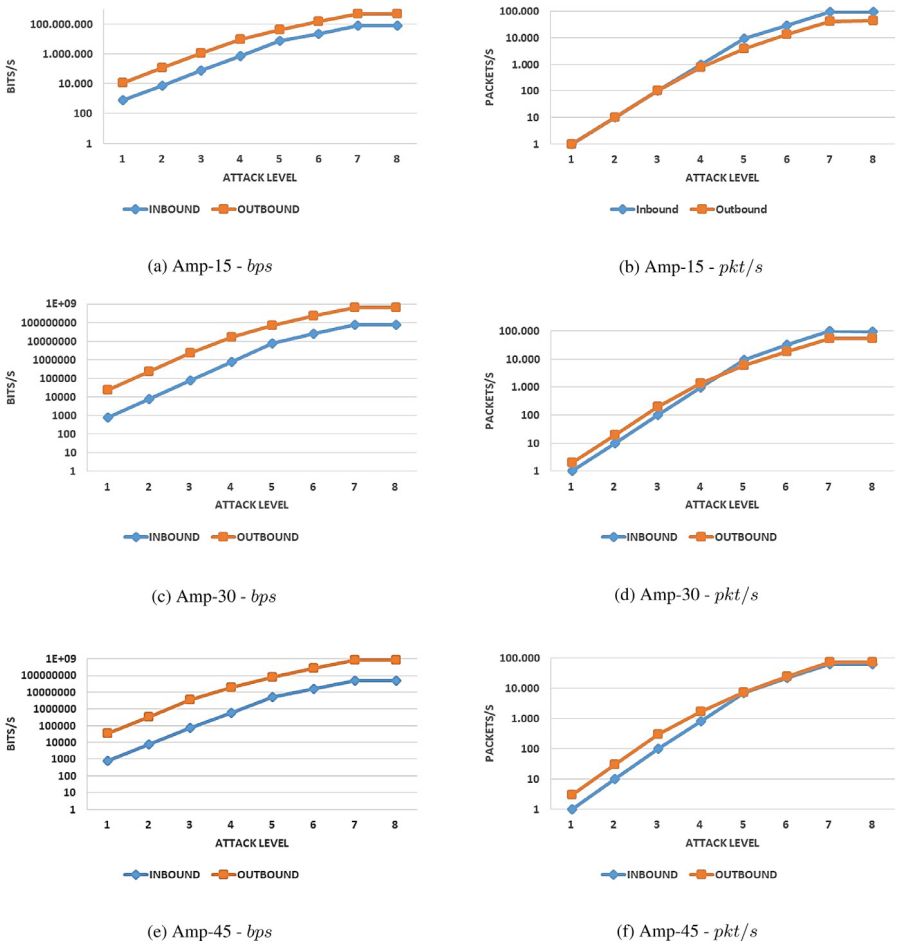
5.5. Attack with DNS

Tables 12 and 13 in the Appendix present results for reflector behavior for different maximum amplification factors of 15×, 30× and 45× in bit rates for the DNS attack in terms of bit and packet flows respectively. Maximum amplification factors observed were, for bit rates: 14,67× for Amp-15, 31× for Amp-30 and 43,81× for Amp-45; whereas for packet rates observed values were: 1× for Amp-15, 2× for Amp-30 and 3× for Amp-45. This can be easily verified in Fig. 8.

5.5.1. DNS amplification

As demonstrated by Figs. 8a and 8b for Amp-15, Figs. 8c and 8d for Amp-30, and Figs. 8e and 8f for Amp-45, different from NTP, maximum amplification rates sustain up to level 3, and saturate from that on, in bits and in packets. Attenuation occurred only for both Amp-15 and Amp-30 from level 5 on, either in bits or in packets.

As for DNS, amplification factor behavior for maximum values tested is presented in Figs. 9a and 9b. Note that the overall behavior for all three maximum factors tested is identical, with graphs shifted according to amplification intensity. For the tree of them, maximum amplification is sustained until level 3, when it starts falling and remains reasonably stable from level 5 on, both in bytes and in packets. For the Amp-45 amplification factor, some residual amplification is sustained from level 5 on, both in bytes and in packets. For Amp-30 and Amp-15 amplification factors, attenuation occurs from level 5 on in bytes and in packets. Unlike NTP, DNS graphs did not converge but conserved their shape with vertical shifts, in bytes, and in packets. This behavior suggests that for DNS saturation point is independent of the maximum amplification factor. Nonetheless, the saturation impact still seems to depend on the initial maximum amplification factor.



(a) Amp-15 - *bps*

(b) Amp-15 - pkt/s

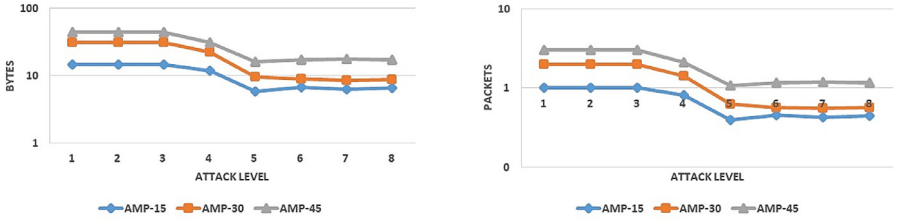
(c) Amp-30 - *bps*

(d) Amp-30 - pkt/s

(e) Amp-45 - *bps*

(f) Amp-45 - pkt/s

Fig. 8. DNS attack.



(a) Bytes

(b) Packets

Fig. 9. DNS amplification.

6. Discussion

In general, test results confirm expectations in terms of amplification and occurrence of saturation behavior but are intriguing in its form and values of saturation points which are close, almost coincidental.

6.1. Amplification

In terms of amplification factor in bps and pkt/s, the highest values observed per protocol are shown in Table 7.

As expected, the highest bit amplification rates are obtained by SNMP followed by NTP. DNS is slightly better than SSDP. In terms of packet amplification, the highest rate is obtained for NTP, followed by SNMP. This is consistent with NTP conforming to the strict 512-byte limit for UDP datagrams so that response is accommodated in several datagrams.

Table 7
Maximum amplification rates observed (bps).

Protocol	Bit rate	Packet rate
SNMP	609,03×	33,40×
SSDP	38,23×	10,00×
NTP	422,81×	100,00×
DNS	43,81×	3,00×

6.2. Saturation behavior

Saturation behavior for the protocols tested is discussed in the sequel.

6.2.1. SNMP behavior

SNMP test results are consistent with previous results [6], either in general reflector behavior as in numerical terms. Results

Table 8
Saturation behavior according to protocol — bit rate amplification.

Protocol		Saturation		Post saturation	
		Start level	Consolidation	Attenuation	Residual
SNMP		3	4		×
SSDP		2	3		×
	60 hosts	2	3	×	
NTP	300 hosts	1	2	×	
	600 hosts	1	2	×	
	Amp-15	3	4		×
DNS	Amp-30	3	4		×
	Amp-45	3	4		×

diverge slightly for higher attack levels but agree on saturation behavior. In previous tests, there was attenuation from level 6 on, in bits and in packets. In this paper, there was some residual amplification after saturation. One possible explanation for this difference is that now the attacker and reflector are more even in terms of computational power than in tests mentioned before. So, the attacker does not overwhelm the reflector with traffic.

6.2.2. SSDP behavior

SSDP, as expected, showed much lower amplification rates than SNMP but produced the same shape in overall behavior, even with some attenuation for higher attack levels in terms of packet amplification.

6.2.3. NTP behavior

NTP also follows the pattern and consolidates saturation from level 2 on attenuating from level 4 on with amplification curves for all three maximum amplification levels tested converging.

6.2.4. DNS behavior

Finally, DNS seems to confirm the trend and saturates from level 3 on consolidating on level 4 with residual amplification. For the three maximum amplification factors tested, curves were preserved and show identical shapes with a vertical shift according to the initial amplification level.

6.2.5. Summary of saturation behavior

Tests for NTP and DNS were also designed to gather information about the way maximum amplification could influence saturation depending on the protocol with very distinct results. With NTP curves converge whilst with DNS they saturate at the same attack level but keep consistent with the maximum amplification value.

Comparing packet rate amplification with bit rate amplification, the first follows the overall pattern of the later, diverging in post saturation behavior. In this case, attenuation was observed in all tests, except SNMP.

Tables 8 and 9 summarize these finding for bit rate and packet rate amplification behavior. They show saturation point start and consolidation, as well as post saturation behavior for the protocols tested.

6.3. Intriguing results

There are two intriguing and suggestive findings when comparing reflector behavior. The first is that for all protocols, reflector behavior is basically the same. The second finding is that not only did the reflector saturate, in terms of unstained maximum amplification, but saturation occurred for roughly the same attack levels.

It was expected that for different protocols, providing amplification in very diverse forms, completely dissimilar implementations with contrasting computational demands, saturation would occur but not necessarily at the same attack levels. So this convergence is striking. It is speculated which architectural characteristic common to test setups is determinant to this convergence. The most likely candidate is related to I/O bus standards, but that requires further investigation.

Table 9
Saturation behavior according to protocol — packet rate amplification.

Protocol		Saturation		Post saturation	
		Start level	Consolidation	Attenuation	Residual
SNMP		3	4		×
SSDP		2	3	×	
	60 hosts	2	3	×	
NTP	300 hosts	1	2	×	
	600 hosts	1	2	×	
	Amp-15	3	4	×	
DNS	Amp-30	3	4	×	
	Amp-45	3	4	×	

There is yet an even more surprising aspect to point out which may also relate to some architectural features. Saturation took place for all attacks, starting at level 2 and confirming on level 3 or starting prompt at level 3 and consolidating on level 4. That represents optimum input probe rates in the order of magnitude between 10 probe/s and 100 probe/s which are extremely low attack input rates when compared the those commonly used typically exceeding tens of thousands of probes per second [35], even if level 4, when saturation is consolidated, is considered (1000 probe/s).

Consequently, maximum attack efficiency is achieved for low probe input rates, minimizing attack execution effort in terms of traffic generation. An attacker might then involve more reflectors and generate more attack traffic without having to increase capacity, despite some additional management complexity. Authors intend to further evaluate the complexity aspects in another research work.

6.4. Comparing our results with real-world cases

At this point, findings are compared with data reported from real events available. [15] provides some real attack data and makes some calculations. In the first wave, the attack reached 75 Gbps and later evolved and reached 300 Gbps

6.4.1. Comparing with the initial attack

According to their report, they initially suffered a 75 Gbps attack which recorded over 30,000 unique reflectors. The reported AR-DDoS attack abused DNS, so that 36 byte long queries amounted to 3000 byte long replies corresponding to an amplification factor of almost 100×.

This amplification rate in the report was calculated considering only amplification at the application layer which amounts to roughly twice the value obtained using Eq. (2), where amplification considers all layers from IP upwards.

Thus, using data from the report, to generate 75 Gbps of attack traffic, the attacker would have to generate 750 Mbps of probe traffic (total attack traffic divided by amplification in bits), as in Eqs. (9)–(11). Considering such case:

$$attacker_{vol_{total}} = \frac{vol_{total}}{Amp_{bit}} \tag{9}$$

$$= \frac{75\ \text{Gbps}}{100} \tag{10}$$

$$= 750\ \text{Mbps} \tag{11}$$

That is the attacker effort in terms of traffic volume. The effective injection probe rate per reflector can be then calculated as 87 probe/s dividing the minimum required rate by the number of mirrors (reflectors) used, probe size in bytes and 8 (1 byte = 8 bits) as in Eqs. (12)–(14). Than we have:

$$probe_{rate_{min}} = \frac{attacker_{gen_{traff}}}{(mirrors \times probe_{size} \times 8\ \text{bit})} \tag{12}$$

$$= \frac{750\ \text{Mbps}}{(30000 \times 36 \times 8\ \text{bit})} \tag{13}$$

$$= 87\ \text{probe/s} \tag{14}$$

As in Eq. (10) the amplification value from the report was calculated according to Eq. (4), this probe rate doubles Eq. (7) to 174 probe/s when Eq. (3) is used. Thus, regardless of the actual probe injection rate used by the real attacker, which is not available, the effective and estimated minimum attack effort required per mirror is a little over level 3 in tests executed, which is consistent with the findings in this paper.

6.4.2. Comparing with the subsequent larger attack

A few days later, the reported attack evolved and reached 300 Gbps [36], which amounts to four times the initially reported attack traffic volume. Assuming that attack conditions were the same as in the initial attack (the number of mirrors used and amplification factor were the same), the effective probe injection rate per reflector is now 348 probe/s (as per Eq. (4)) which normalized according to Eq. (7) doubles to 696 probe/s and attack effort required per mirror falls between levels 3 and 4 of the findings provided in this research work.

It must be pointed out that the real attack data obtained refers to AR-DDoS attacks abusing DNS, which showed a similar saturation point as that found for tested protocols. In this case, between attack levels 2 and 3, as in the initial attack, and later consolidates between 3 and 4, as in the subsequent larger attack.

For DNS test results specifically, the saturation point for is consistent with figures calculated from initial attack data, especially for Amp-45. However, in the subsequent 300 Gbps attack those calculations assumed that an amplification rate of 100× was sustained, corresponding to 50× when Eq. (2) is used.

It is observed that was not the case for Amp-45 (lines 3 and 4 in Table 12) as mirror generated bit rates are not consistent. Calculating the rate generated per mirror in the final attack reported (Eqs. (15)–(17)), than there is:

$$vol_{gen} = \frac{vol_{total}}{mirrors} \tag{15}$$

$$= \frac{300\ \text{Gbps}}{30000} \tag{16}$$

$$= 10\ \text{Mbps} \tag{17}$$

It results that each mirror generated 10 Mbps which is consistent with level 4 for amp-45 (Table 12) with probe rate of 798 probe/s and amplification rate of 31,12× (line 4 for amp-45 in Tables 12 and 13, respectively). So, attacker effort in terms of generated probes and traffic volume was much higher than initially estimated. Nonetheless, this value is consistent with saturation already occurring on level 4. Note that the ratio between the probe rate calculated with reported attack data and the observed probe rate is $696/798 = 0,872$ coincides with the ratio between the maximum amplification rate observed and the one calculated with reported data ($43,81/50 = 0,876$ as amplification and probe rates are inversely proportional). This congruence is justified by the DNS shape-preserving behavior observed during tests for different initial maximum amplification rates (Fig. 9).

6.4.3. Comments

These results provide further evidence that the methodology used is consistent, appropriate and it is capable of reproducing what is executed in real-world attacks. Furthermore, it corroborates the results obtained for the protocols tested. It should be noted, in the cases presented in [15] and [36], the attacker data is not complete and not necessarily precise. This was one of the main motivations for this investigation and its methodology.

7. Conclusion and further directions

Results corroborate previous claims that amplified reflection attacks if directed towards the IoT infrastructure would impact it severely, possibly rendering the attack ineffective in hitting the final target. Note that reflector configurations used were much more powerful than that of a typical IoT device, even if only so-called smart devices are considered.

This does not totally exonerate the potential threat from IoT infrastructure abuse by AR-DDoS attacks. First, IoT has a huge number of potential devices that can be abused. Second, if the attacker modulates probe rates to avoid reflector saturation and increase the number of reflectors involved, high volumes of traffic can be generated. However, more reflectors imply more complex attack management, thus better orchestration is needed by the attacker.

In any case, low probe injection rates match IoT device limited resources so that it is feasible to use them also as probe injectors for reflection attacks. Again, this would add attack management complexity. But there is already evidence that DDoS is evolving in terms of more refined forms of execution.

Usually, DDoS attacks are executed in a “brute force” fashion. An attacker uses all capacity needed to hit the target, given prior knowledge of its capacity. However, there is already an indication that DDoS execution is changing. Techniques like “carpet bombing” [37] and pulse wave attacks [38] demonstrate this tendency.

Carpet bombing DDoS attacks scatter traffic within a specific IP subnet or CIDR block (for example, a /20 block), making it more difficult to detect the attack and also to mitigate it, potentially resulting in outages due to the flood of attack traffic across network devices and internal links. Pulse wave attacks, on its turn, consist of a series of short-lived high-intensity traffic pulses occurring in synchronized succession to circumvent hybrid mitigation (in premise jointly with cloud). These techniques target not only the final victim but also the mitigating mechanisms used in defense. Consequently, DDoS attacks are already security-aware.

As already discussed, maximum attack efficiency comes with lower attack effort, *i.e* lower input probe rates. The first makes life easier for attackers while the latter makes detection and mitigation even more complex.

The additional management burden due to the possible inclusion of more reflectors or even injectors might demand better orchestration and coordination from attackers, particularly if using botnets.

In terms of mitigation, this means that new requirements for detecting and treating AR-DDoS are necessary. This investigation tries to elucidate the direction those requirements could evolve.

Table 10
NTP attack (bps).

Level	60 hosts			300 hosts			600 hosts		
	Reflector		Amplification	Reflector		Amplification	Reflector		Amplification
	Inbound	Outbound		Inbound	Outbound		Inbound	Outbound	
1	912	38 560	42,28	912	192 800	211,40	912	385 600	422,81
2	9120	385 600	42,28	9120	1 609 304	176,46	9120	1 969 640	215,97
3	91 200	2 054 088	22,52	91 200	2 126 000	23,31	91 200	2 169 384	23,79
4	912 000	2 217 392	2,43	912 000	2 286 992	2,51	912 000	2 260 192	2,48
5	9 119 088	3 193 152	0,35	9 119 088	3 184 280	0,35	9 119 088	3 146 688	0,35
6	15 606 688	5 052 712	0,32	16 248 464	4 857 592	0,30	15 729 216	4 513 640	0,29
7	66 512 296	8 566 680	0,13	65 521 816	7 943 360	0,12	65 488 800	9 875 216	0,15
8	78 954 024	8 643 224	0,11	78 927 488	8 276 320	0,10	76 826 744	10 153 424	0,13

Table 11
NTP attack (pkt/s).

Level	60 hosts			300 hosts			600 hosts		
	Reflector		Amplification	Reflector		Amplification	Reflector		Amplification
	Inbound	Outbound		Inbound	Outbound		Inbound	Outbound	
1	1	10	10,00	1	50	50,00	1	100	100,00
2	10	100	10,00	10	417	41,70	10	511	51,10
3	100	533	5,33	100	551	5,51	100	562	5,62
4	1000	575	0,58	1000	593	0,59	1000	586	0,59
5	9999	828	0,08	9999	826	0,08	9999	816	0,08
6	17 112	1310	0,08	17 816	1259	0,07	17 247	1170	0,07
7	72 930	2221	0,03	71 844	2060	0,03	71 808	2561	0,04
8	86 572	2241	0,03	86 543	2146	0,02	84 240	2633	0,03

Table 12
DNS Attack (bps).

Level	Amp-15			Amp-30			Amp-45		
	Reflector		Amplification	Reflector		Amplification	Reflector		Amplification
	Inbound	Outbound		Inbound	Outbound		Inbound	Outbound	
1	768	11 264	14,67	768	23 808	31,00	768	33 648	43,81
2	7680	112 640	14,67	7680	238 080	31,00	7680	336 480	43,81
3	76 800	1 126 400	14,67	76 800	2 380 800	31,00	76 800	3 364 800	43,81
4	762 624	8 977 408	11,77	741 888	16 260 864	21,92	606 480	18 876 528	31,12
5	7 433 472	42 555 392	5,72	7 286 016	69 947 904	9,60	5 145 200	81 360 864	15,81
6	23 044 608	151 917 568	6,59	24 748 032	218 271 744	8,82	16 488 200	281 263 632	17,06
7	76 182 528	478 720 000	6,28	75 634 176	643 054 080	8,50	47 406 520	824 005 872	17,38
8	75 976 704	493 757 440	6,50	74 860 800	652 124 928	8,71	47 430 080	813 743 232	17,16

Table 13
DNS attack (pkt/s).

Level	Amp-15			Amp-30			Amp-45		
	Reflector		Amplification	Reflector		Amplification	Reflector		Amplification
	Inbound	Outbound		Inbound	Outbound		Inbound	Outbound	
1	1	1	1,00	1	2	2,00	1	3	3,00
2	10	10	1,00	10	20	2,00	10	30	3,00
3	100	100	1,00	100	200	2,00	100	300	3,00
4	993	797	0,80	966	1366	1,41	798	1683	2,11
5	9679	3778	0,39	9487	5876	0,62	6770	7254	1,07
6	30 006	13 487	0,45	32 224	18 336	0,57	21 695	25 077	1,16
7	99 196	42 500	0,43	98 482	54 020	0,55	62 377	73 467	1,18
8	98 928	43 835	0,44	97 475	54 782	0,56	62 408	72 552	1,16

Summarizing, results demonstrate that the study of mirror saturation dynamics assessing reflector behavior for several protocols (SNMP, SSDP, NTP, and DNS), as well as their subsequent comparison and characterization of saturation provided a further indication that for using IoT devices is feasible but effectively increases attack complexity. Consequently, it was possible to identify evolution trends in AR-DDoS and its consequences in terms of detection and mitigation requirements.

Further investigation directions include testing the attack for other protocols, like CoAP [39], over specific to IoT devices in scenarios using them as reflectors to verify and possibly corroborate findings related to saturation behavior and saturation point.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgments

Authors would like to thank Henrique Hirata, Igor Miranda, Alexander Vieira and Rodrigo Saldanha for their relevant contribution developing the tools used. João Gondim gratefully acknowledges the support from CyberSec vLab (Laboratório Virtual de Segurança Cibernética), Rede GigaCandanga, and Project

"EAGER: USBRCCR: Collaborative: Securing Networks in the Programmable Data Plane Era" funded by National Science Foundation (NSF), USA and Rede Nacional de Ensino e Pesquisa (RNP), Brazil (Brazilian National Research Network). Robson de Oliveira Albuquerque gratefully acknowledges the support from the Brazilian Research Councils CNPq (Grant 465741/2014-2 INCT on Cyber security), CAPES (Grant 23038.007604/2014–69 FORTE), FAPDF (Grants 0193.001366/2016 UIoT and 0193.001365/2016 SSDDC), as well as the LATITUDE/UnB Laboratory (Grant 23106.099441/2016-43 SDN) and the Institutional Security Office of the Presidency of the Republic of Brazil (Grant 002/2017).

Appendix

See Tables 10–13.

References

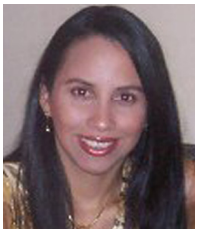
[1] Radware: History of DDoS attacks, 2019, https://security.radware.com/ddos-knowledge-center/ddos-chronicles/ddos-attacks-history/ (accessed Apr. 2019).
[2] MIT technology review: The first DDoS attack was 20 years ago. This is what we've learned since, 2019, https://www.technologyreview.com/s/613331/the-first-ddos-attack-was-20-years-ago-this-is-what-weve-learned-since (accessed Apr. 2019).
[3] V. Paxson, An analysis of using reflectors for distributed denial-of-service attacks, ACM SIGCOMM Comput. Commun. Rev. 31 (2001) 38–47.
[4] C. Rossow, Amplification hell: Revisiting network protocols for DDoS abuse, in: Proceedings of the 21st Annual Network and Distributed System Security Symposium, NDSS 2014, San Diego, CA, USA, February 2014, pp. 23–26.
[5] J.J.C. Gondim, R.de O. Albuquerque, Mirror saturation in amplified reflection DDoS, in: Andrés Caro Lindo, Luis Javier García Villalba, Ana Lucila Sandoval Orozco (Eds.), In Actas de Las V Jornadas Nacionales de Ciberseguridad Junio 5-7, 2019, Universidad de Extremadura, Servicio de Publicaciones, 2019.
[6] J.J.C. Gondim, R. de Oliveira Albuquerque, A. Clayton Alves Nascimento, L. García Villalba, T.H. Kim, A methodological approach for assessing amplified reflection distributed denial of service on the internet of things, Sensors 16 (11) (2016) 1855.
[7] H. Mustapha, A. Alghamdi, DDoS attacks on the internet of things and their prevention methods, in: Proceedings of the 2nd International Conference on Future Networks and Distributed Systems, 2018, http://dx.doi.org/10.1145/3231053.3231057.
[8] C. Zhang, R. Green, Communication security in internet of thing: Preventive measure and avoid DDoS attack over IoT network, in: Proceedings of the 18th Symposium on Communications & Networking, 2015, pp. 8-15, ISBN: 978-1-5108-0100-4.
[9] Arturs Lavrenovs, Towards measuring global DDoS attack Capacity, in: 2019 11th International Conference on Cyber Conflict (CyCon), IEEE, 2019, pp. 1–15.
[10] Ahmed K. Soliman, Cherif Salama, Hoda K. Mohamed, Detecting DNS reflection amplification ddos attack originating from the cloud, in: 2018 13th International Conference on Computer Engineering and Systems (ICCES), IEEE, 2018, pp. 145–150.
[11] Ronierison Maciel, et al., Impact of a DDoS attack on computer systems: An approach based on an attack tree model, in: 2018 Annual IEEE International Systems Conference (SysCon), IEEE, 2018, pp. 1–8.
[12] A. Arış, .S.F. Oktuğ, S.B.Ö. Yalçın, Internet-of-Things security: Denial of service attacks, in: Proceedings of the 2015 23nd Signal Processing and Communications Applications Conference (SIU), Malatya, Turkey, May 2015, pp. 903–906.
[13] D. Goodin, Record-breaking ddos reportedly delivered by > 145*k* hacked Cameras, Arstechnica (2016) http://arstechnica.com/security/2016/09/botnet-of-145k-cameras-reportedly-deliver-internets-biggest-ddos-ever/ (accessed on Oct 2016).
[14] P. Bright, Spamhaus DDoS grows to internet-threatening size, Arstechnica (2013) http://arstechnica.com/security/2013/03/spamhaus-ddos-grows-to-internetthreatening-size/ (accessed 12 2016).
[15] M. Prince, The DDoS that knocked spamhaus offline (and how we mitigated it), Cloudflare blog (2013) https://blog.cloudflare.com/the-ddos-that-knocked-spamhaus-offline-and-ho/ (accessed May 2016).
[16] C. Seaman, Threat Advisory: Mirai Botnet, Technical Report, Akamai Technologies, 2016, https://www.akamai.com/uk/en/resources/our-thinking/threat-advisories/akamai-mirai-botnet-threat-advisory.jsp, (accessed Apr 2019).
[17] Anna-senpai: Mirai source code, 2016, https://github.com/jgamblin/Mirai-Source-Code (accessed May 2018).
[18] L.A.B. Pacheco, J.J.C. Gondim, P.A.S. Barreto, E. Alchieri, Evaluation of distributed denial of service threat in the internet of things, in: 2016 IEEE 15th International Symposium on Network Computing and Applications (NCA), 2016, pp. 89–92.
[19] Ladislav Huraj, Marek Simon, Tibor Horák, IoT measuring of UDP-based distributed reflective DoS attack, in: 2018 IEEE 16th International Symposium on Intelligent Systems and Informatics (SISY), IEEE, 2018, pp. 000209–000214.
[20] M. McDowell, Understanding Denial-of-Service Attacks, Technical Report, US Department of Homeland Security, 2009.
[21] F. Ali, IP spoofing, Internet J. 10 (4) (2007) Cisco Press, http://www.cisco.com/web/about/ac123/ac147/archivedissues/ipj10-4/104ip-spoofing.html (accessed October 2019).
[22] J. Case, M. Fedor, M. Schoffstall, J. Davin, Simple Network Management Protocol (SNMP) RFC 1157 (Historic), Internet Engineering Task Force (IETF), 1990.
[23] J. Case, K. McCloghrie, M. Rose, S. Waldbusser, Introduction To Community-Based SNMPv2 RFC 1901, Internet Engineering Task Force (IETF), 1996.
[24] H.D. Moore, Security Flaws in Universal Plug and Play, Rapid7 Whitepaper, 2018, https://information.rapid7.com/rs/411-NAK-970/images/SecurityFlawsUPnP%20%281%29.pdf (accessed Sep. 2018).
[25] UPnP Forum: UPnP device architecture 1.0, 2018, http://upnp.org/specs/arch/UPnP-arch-DeviceArchitecture-v1.0.pdf (accessed Sep. 2018).
[26] Majkowski, Marek: Stupidly simple ddos protocol (SSDP) generates 100 *Gbps* ddos, cloudflare blog, 2018, https://blog.cloudflare.com/ssdp-100gbps/ (accessed Sep. 2018).
[27] D.L. Mills, U. Delaware, J. Martin (Eds.), Network Time Protocol Version 4: Protocol and Algorithms Specification, in: RFC 5905, IETF, 2010, https://tools.ietf.org/html/rfc5905, (accessed May 2019).
[28] John Graham-Cumming, Understanding and mitigating NTP-based ddos attacks, Cloudflare (2014) https://blog.cloudflare.com/underst{and}ing-and-mitigating-ntp-based-ddos-attacks/ (accessed May 2019).
[29] Paul Mockapetris, et al., RFC 1034: Domain Names—Concepts and Facilities, IETF, Network Working Group, 1987, Nov. 1987.
[30] Paul Mockapetris, et al., RFC-1035 Domain Names-Implementation and Specification, Vol. 55, IETF, Network Working Group, 1987, https://www.ietf.org/rfc/rfc1035.txt (accessed May 2019).
[31] D. Eastlake, Domain Name System Security Extensions, in: RFC 2535, IETF, 1999, https://tools.ietf.org/html/rfc2535 (accessed May 2019).
[32] P. Vixie, Extension Mechanisms for DNS (EDNS0), in: RFC 2671, IETF, 1999, http://www.networksorcery.com/enp/rfc/rfc2671.txt, (accessed May 2019).
[33] NEXUSGUARD : DDoS Threat Report 2018 Q3, 2018, https://www.nexusguard.com/threat-report-q3-2018 (accessed Mar 2019).
[34] Wireshark foundation: Wireshark, 2015, https://www.wireshark.org, (accessed May 2018) 2019.
[35] M. Majkowski, How to receive a million packets per second, Cloudflare (2015) https://blog.cloudflare.com/how-to-receive-a-million-packets/ (accessed Dec 2018).
[36] J. Vijayan, Update: Spamhaus hit by biggest-ever ddos attacks, Computerworld (2013) https://www.computerworld.com/article/2495967/update--spamhaus-hit-by-biggest-ever-ddos-attacks.html, (accessed May 2019).
[37] S. Bjarnason, DDoS defences in the terabit era: Attack trends, carpet bombing, APNIC blog, 2018, https://blog.apnic.net/2018/12/04/ddos-defences-in-the-terabit-era-attack-trends-carpet-bombing/ (accessed Dec. 2018).
[38] Imperva: Attackers Use DDoS Pulses To Pin Down Multiple Targets, Send Shock Waves Through Hybrids, Technical Report, Imperva Incapsula Whitepaper,, 2017.
[39] Z. Shelby, K. Hartke, C. Bormann, The Constrained Application Protocol (CoAP), in: RFC 7252, IETF, 2014, http://www.rfc-editor.org/rfc/rfc7252.txt, (accessed Dec. 2018).



Joao J. C. Gondim is from Recife, Brazil, where he obtained a degree in Electrical Engineering (Electronics) at UFPE (Pernambuco Federal University) in 1984. He was also awarded an MSc in Computing Science at Imperial College, University of London, in 1987 and a PhD in Electrical Engineering at UnB (University of Brasilia, 2017). Since 1994, Professor Gondim is a lecturer at Department of Computing Science (CIC) at UnB where he is a tenured member of faculty. His research interests are information and cyber security.



Robson de Oliveira Albuquerque holds a PhD in information systems from University Complutense of Madrid in Spain (2016) and also a doctor degree in electrical engineering from University of Brasilia in Brazil (2008). Additionally he finished his advanced studies (DEA) at University Complutense of Madrid (2007) and received his master degree in electrical engineering from University of Brasilia (2003). He holds a specialization (MBA) in computer networks from Educational Union of Brasilia (2001) and graduated in computer science at Catholic University of Brasilia (1999). He is a researcher at University of Brasilia and member of GASS research group at University Complutense of Madrid (Spain). His fields of interest and research include Cyber Security, Network Security, Information Security, Distributed Systems and Computer Networks.



Ana Lucila Sandoval Orozco was born in Chivolo, Magdalena, Colombia in 1976. She received a Computer Science Engineering degree from the Universidad Autonoma del Caribe (Colombia) in 2001. She holds a Specialization Course in Computer Networks (2006) from the Universidad del Norte (Colombia), and holds a M.Sc. in Research in Computer Science (2009) and a Ph.D. in Computer Science (2014), both from the Universidad Complutense de Madrid (Spain). She is currently researcher at University of Brasilia and member of GASS research group at Universidad Complutense de Madrid (Spain). Her main research interests are coding theory, information security and its applications.